

计算机网络

西安交通大学
计算机科学与技术学院

西安交通大学
Xi'an Jiaotong University

第八章 网络安全

- 网络安全概述
- 密码体制
- 网络安全技术
- IPSec
- 网络管理
- 区块链

西安交通大學
Xi'an Jiaotong University

8.1 网络安全概述

- **国际标准化组织ISO对计算机网络安全（Network Security）的定义**
  - ✓ 为数据处理系统建立和采用的安全防范技术，以保护计算机硬件、软件和数据不因偶然和恶意的原因遭到破坏、更改和泄露。

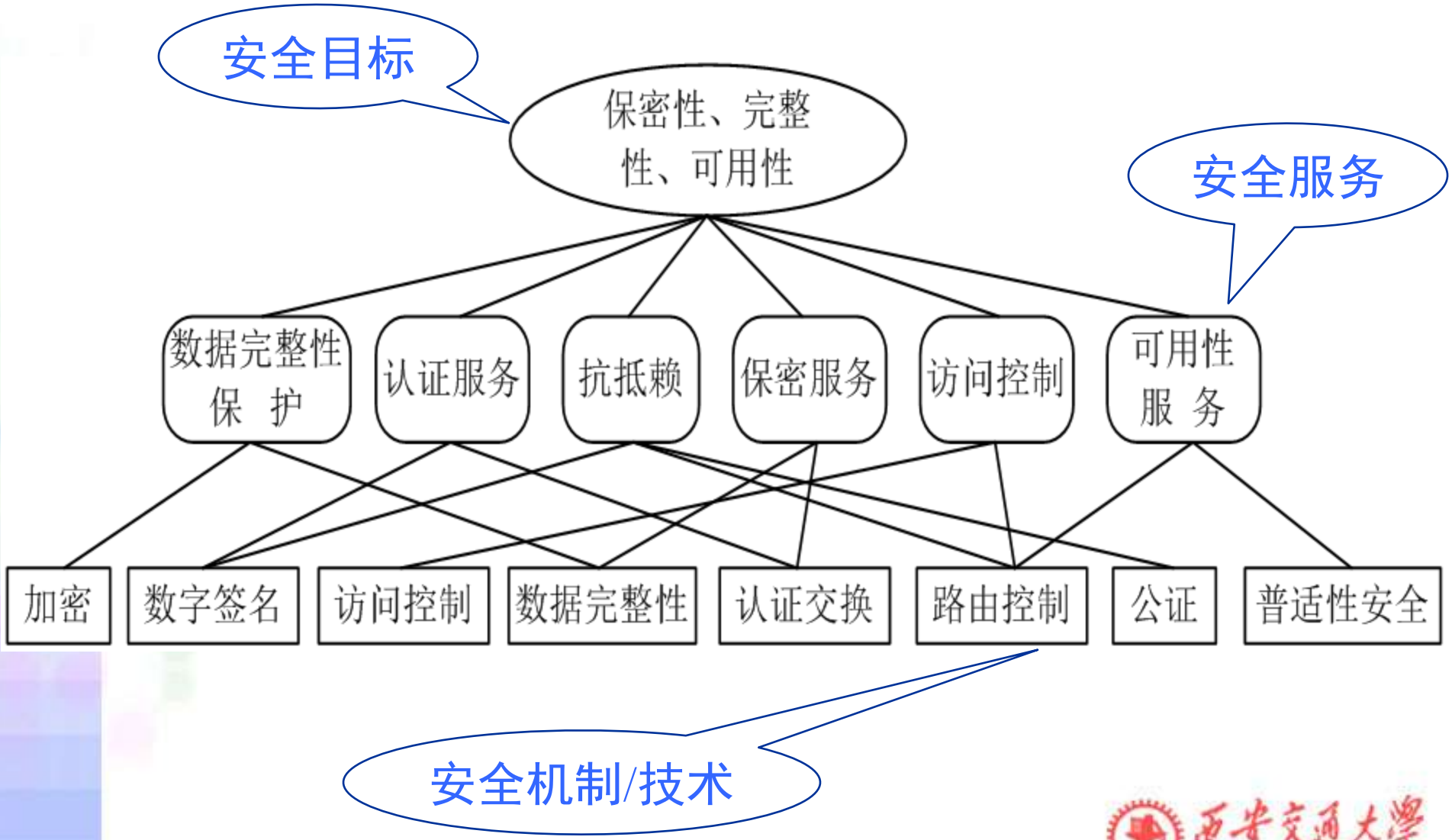
西安交通大学 Xi'an Jiaotong University

网络安全威胁

- 网络安全面临的主要威胁
  - ✓ 非授权访问
  - ✓ 信息泄漏或丢失
  - ✓ 破坏数据完整性
  - ✓ 拒绝服务攻击DoS
  - ✓ 利用网络传播病毒等

西安交通大学 Xi'an Jiaotong University

网络安全目标、服务与机制



西安交通大學 Xi'an Jiaotong University

8.2 密码学/密码体制

- 密码学包括（cryptology）密码编码学和密码分析学。
- 密码编码学是密码体制的设计学，而密码分析学则是在未知密码的情况下从密文推演出明文的技术。
- 根据密钥的特点，密码体制分为非对称密钥体制和对称密钥体制两种。

西安交通大学 Xi'an Jiaotong University

相关术语

- **明文**：信息的原始形式（ plainttext，记为P）
- **密文**：明文加密后的形式（ciphertext，记为C）
- **加密**：明文变成密文的过程（encrypt，记为E），加密算法实现的。
- **解密**：密文还原成明文的过程（decrypt，记为D），解密算法实现。
- **密钥**：加密和解密算法实现过程中需要有通信双方掌握的专门信息参与，这种专门信息称为密钥（key，记为K）。

西安交通大學 Xi'an Jiaotong University

对称密钥体制

- 对称密钥体制又称为传统密钥、秘密密钥、单钥密钥加密算法
- 对称密钥体制的核心是加密和解密采用相同的密钥。
- 保密性仅取决于对密钥的保密，而加密与解密算法是公开的。

西安交通大学 Xi'an Jiaotong University

流密码与块密码

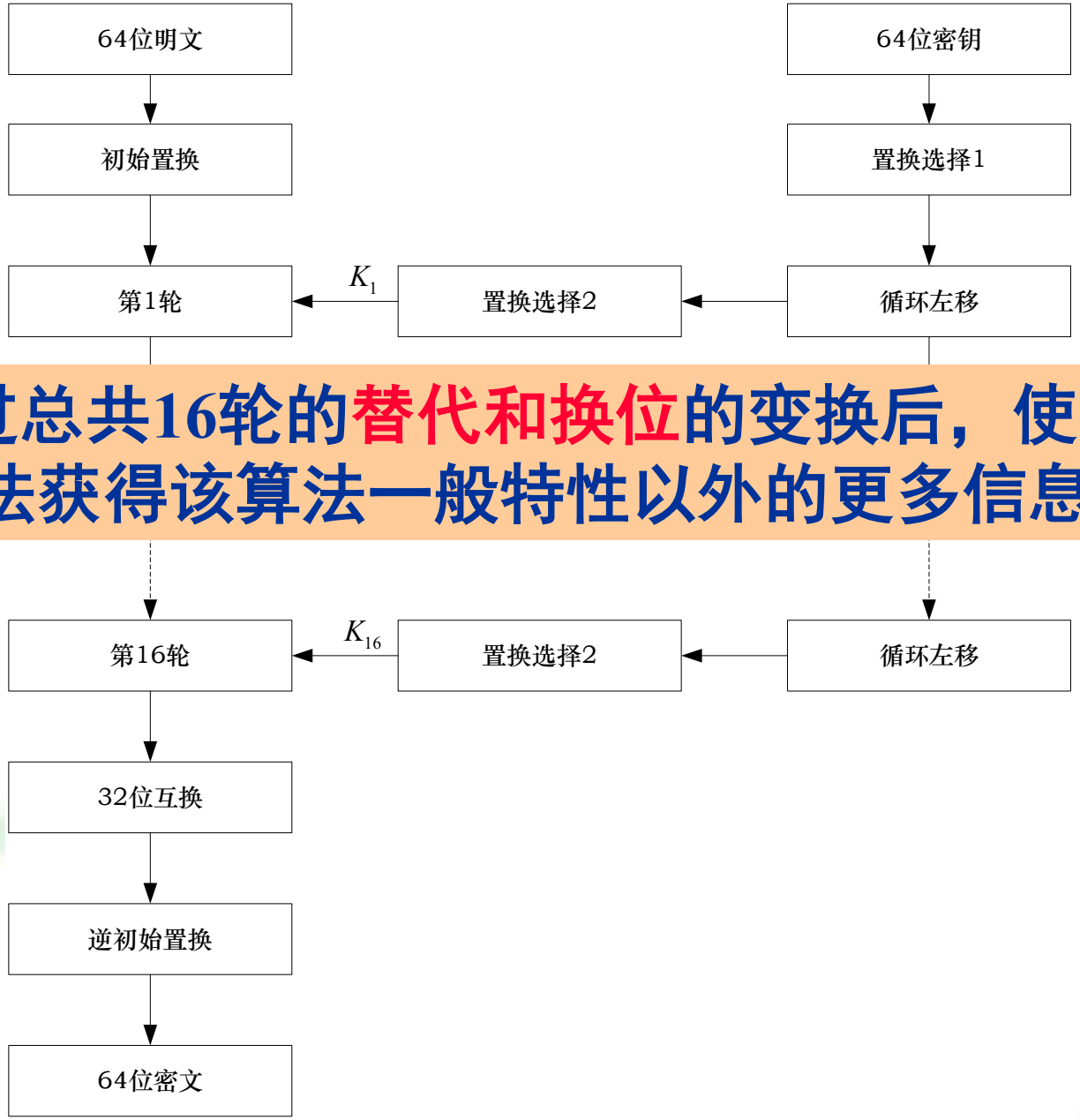
- 对称密钥加密算法可分为两类：
  - ✓流密码（stream cipher）：一次只对明文中的单个位（或字节）加密运算，又称为序列算法、序列密码；
  - ✓块密码（block cipher）：对明文的一组位进行加密运算，又称为分组密码。

西安交通大学 Xi'an Jiaotong University

DES算法

- DES算法（数据加密标准） 是世界上第一个公认的实用密码算法标准，是一种典型的分组加密算法。
- 加密前，先对整个的明文进行分组，每一个分组长64位；
- 使用密钥64位，对每一个64位分组进行加密处理。
- 最后将各分组密文串接，得出整个的密文。

西安交通大学 Xi'an Jiaotong University



DES经过总共16轮的替代和换位的变换后，使得密码分析者无法获得该算法一般特性以外的更多信息。

DES算法流程

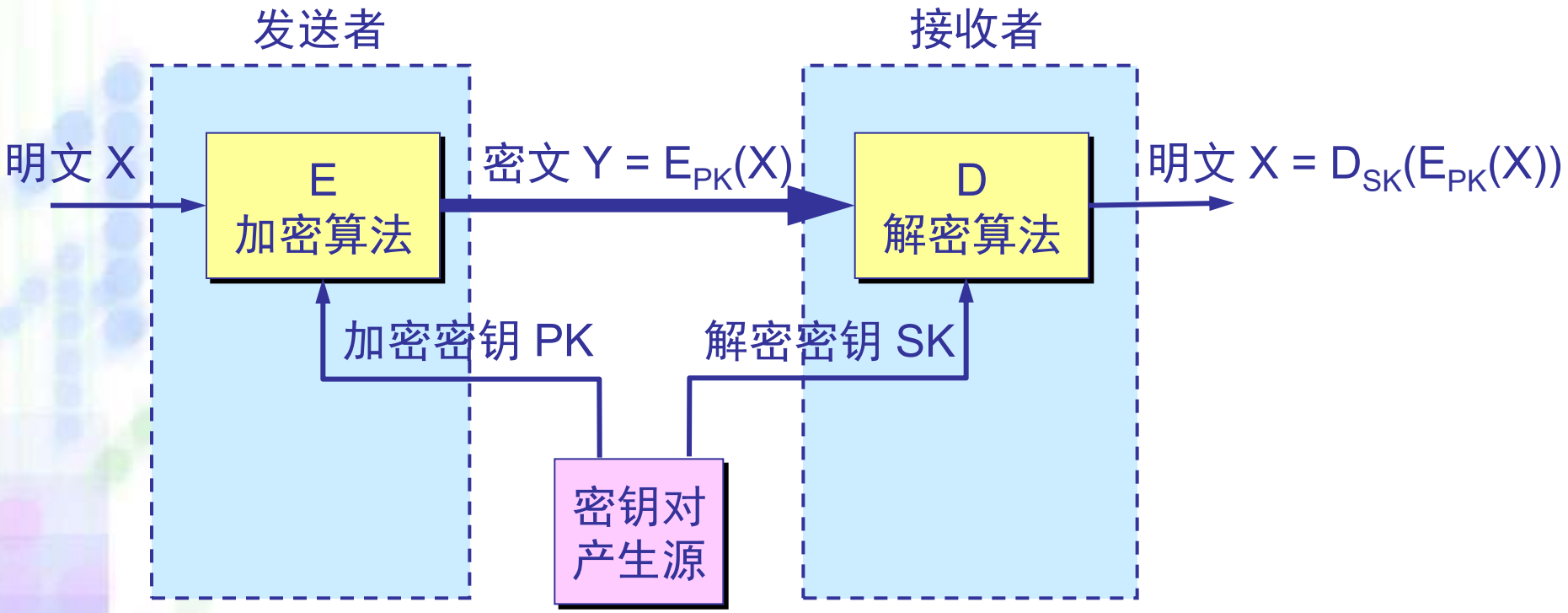
西安交通大学 Xi'an Jiaotong University

公开密钥体制

- 相对于对称加密算法，这种方法也叫做非对称加密算法，需要公开密钥（public key）和私有密钥（private key）两个密钥。
- 公开密钥（加密密钥）和非对称加密解密算法是公开的，但私有密钥（解密密钥）是保密的，由密钥的所有者妥善保管。
- 公开密钥体制中最著名的是RSA算法

西安交通大学 Xi'an Jiaotong University

公开密钥密码体制



西安交通大學
Xi'an Jiaotong University

公开密钥算法的特点

（1）发送者用接受者的加密密钥 PK 对明文 X 加密后，接收者用自己的解密密钥 SK 解密，即可恢复出明文，或写为：

$$D_{SK}(E_{PK}(X)) = X$$

(2) 加密密钥是公开的，但不能用它来解密，即

$$D_{PK}(E_{PK}(X)) \neq X$$

(3) 在计算机上可容易地产生成对的 PK 和 SK。

(4) 从已知的 PK 实际上不可能推导出 SK。

(5) 加密和解密算法都是公开的。

西安交通大學 Xi'an Jiaotong University

数字签名和消息认证

- 除了信息的保密之外，如何保证信息的来源是真实的，保证收到的信息是可靠的而没有被非法篡改，也是非常重要的。
- 认证包括用户身份认证和消息可靠性认证
  - ✓用户身份认证用于鉴别用户的身份是否是合法用户，可以利用数字签名技术来实现的。
  - ✓消息认证（又称报文鉴别）主要用于验证所收到的消息确实是来自真正的发送方且未被修改的消息。

西安交通大學 Xi'an Jiaotong University

消息认证

- 用于消息认证最常用的技术是消息认证码（MAC）和散列函数。
- 消息认证码是在一个密钥的控制下将任意长的消息映射到一个简短的定长数据分组，将它附加在消息后。接收者通过重新计算MAC来对消息进行认证。
- 散列函数（Hash运算）：通过散列函数先计算整个消息摘要，再对摘要计算消息认证码，从而可以大大减少计算量。

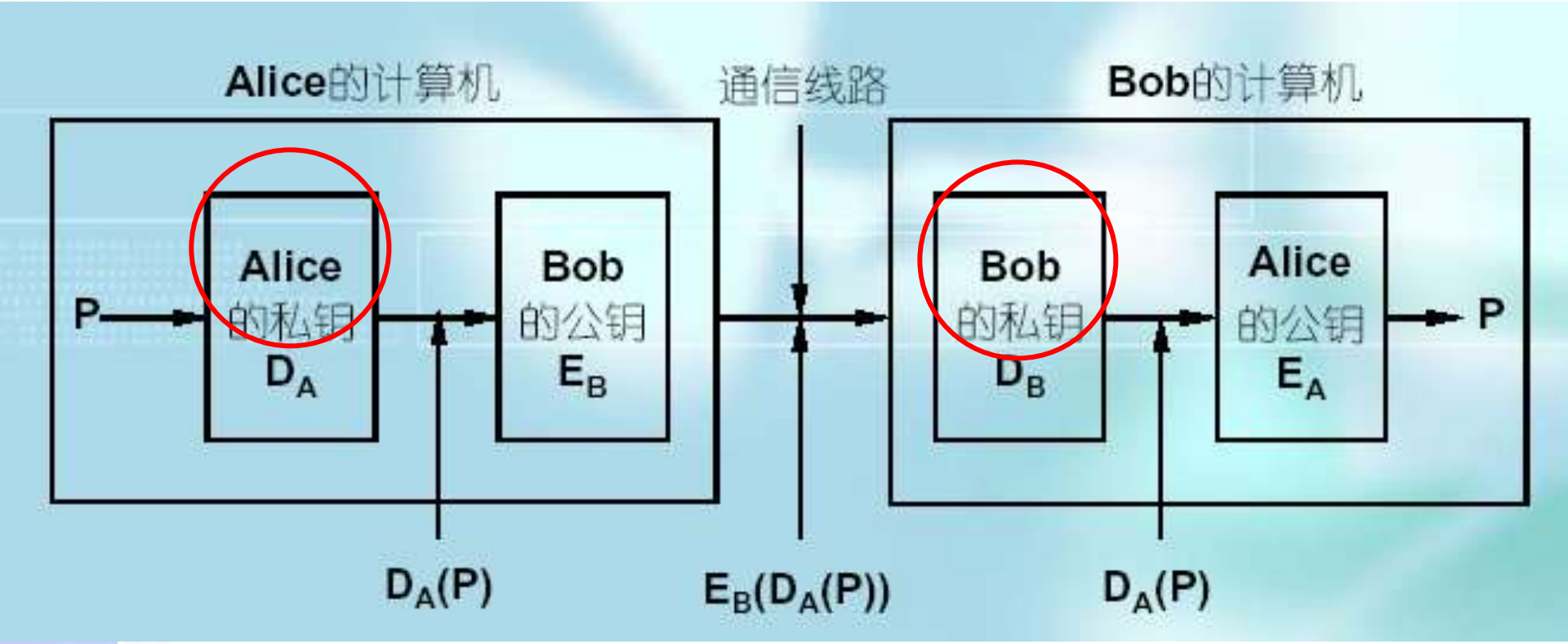
西安交通大学 Xi'an Jiaotong University

数字签名

- 当通信双方发生了下列异常情况时，数字签名技术能够解决引发的争端：
  - ✓ **否认**：发送方不承认自己发送过某一报文。
  - ✓ **伪造**：接收方自己伪造一份报文，并声称它来自发送方。
  - ✓ **冒充**：网络上的某个用户冒充另一个用户接收或发送报文。
  - ✓ **篡改**：接收方对收到的报文进行篡改。

西安交通大学 Xi'an Jiaotong University

采用公钥机制的数字签名



西安交通大學
Xi'an Jiaotong University

密钥的分发和管理

问题:

- ✓如何解决两个实体通过网络实现对称密钥的共享?

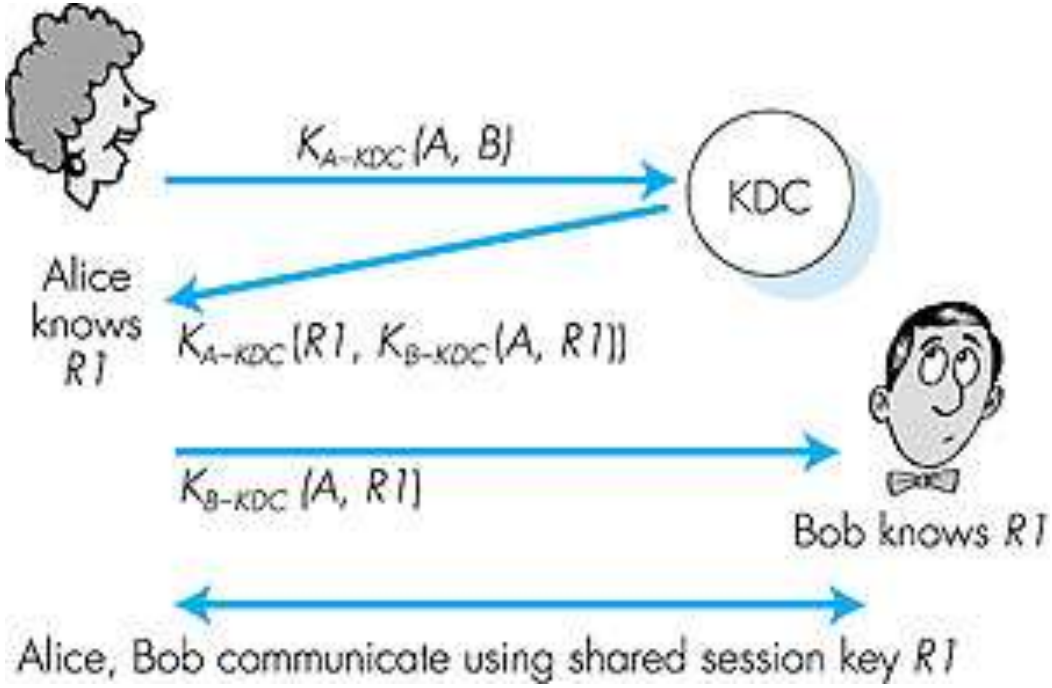
解决办法:

- ✓具有公信力的密钥分发中心（key distribution center (KDC) ）来作为诸多实体间的中介

西安交通大学 Xi'an Jiaotong University

密钥分发中心KDC

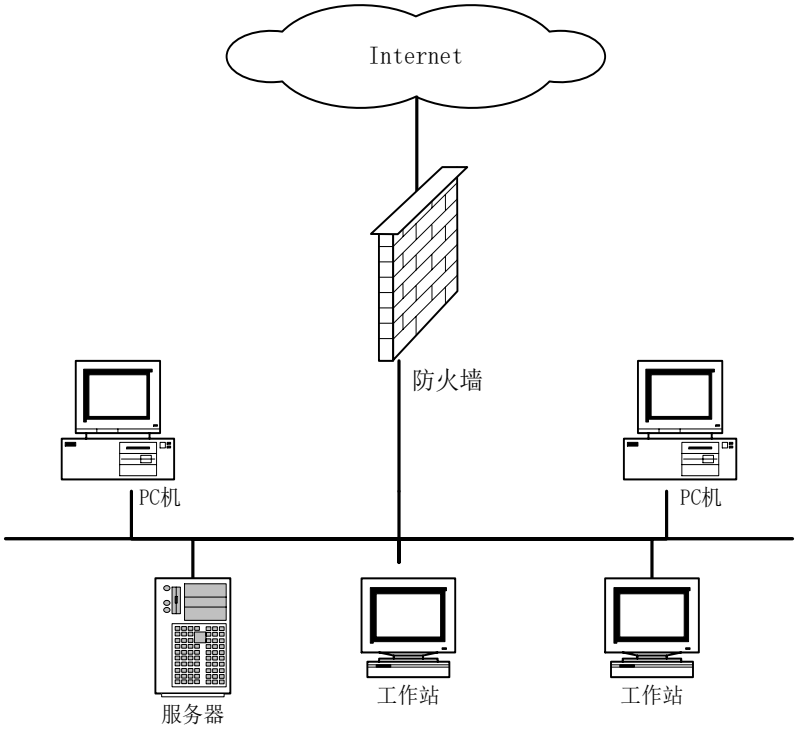
- Alice,Bob 需要共享对称密钥.
- KDC: 为每个注册的用户提供不同的密钥服务.
- Alice, Bob 在KDC注册后，获取了自己的对称密钥, $K_{A\text{-}KDC}$ $K_{B\text{-}KDC}$.



西安交通大學 Xi'an Jiaotong University

8.3 网络安全技术-防火墙

- 网络防火墙用来加强网络之间访问控制。
- 防止外部网络用户以非法手段进入内部网络，访问内部网络资源。



西安交通大学 Xi'an Jiaotong University

防火墙基本特征

- 防火墙是位于两个(或多个)网络间，实施网络之间访问控制的一组组件集合。它具有以下三个方面的基本特性：
  - ✓内、外网间的所有数据流都须经过防火墙;
  - ✓只有符合安全策略的数据流才能通过防火墙;
  - ✓防火墙自身应具有强的抗攻击免疫力。

西安交通大學 Xi'an Jiaotong University

防火墙的功能

- 创建一个阻塞点
- 隔离不同网络，防止内部信息的外泄以及外部非法信息的侵入
- 强化安全策略
- 有效地审计和记录内、外部网络上的活动

西安交通大學 Xi'an Jiaotong University

防火墙分类

- 防火墙实现方式
  - ✓软件防火墙
  - ✓硬件防火墙
- 防火墙的技术类型
  - ✓包过滤型
  - ✓状态监测型
  - ✓应用代理型

西安交通大學 Xi'an Jiaotong University

包过滤防火墙

- 包过滤（packet filter）又称“报文过滤”，它是防火墙最基本的过滤技术。
- 防火墙根据数据包头所含的源、目的IP地址、协议类型(TCP包、UDP包、ICMP包)、源、目的端口等信息，确定该数据包是否允许通过。

西安交通大学 Xi'an Jiaotong University

状态监测防火墙

- 状态监测防火墙是包过滤防火墙的智能升级版，它克服了包过滤防火墙“无记忆力”的致命缺点。
- 状态监测防火墙不仅要看单个数据包，更要关心数据包之间“连接的状态”。
  - ✓ 内部维持一个状态连接表，用来动态记录所有合法连接的完整会话信息

西安交通大学 Xi'an Jiaotong University

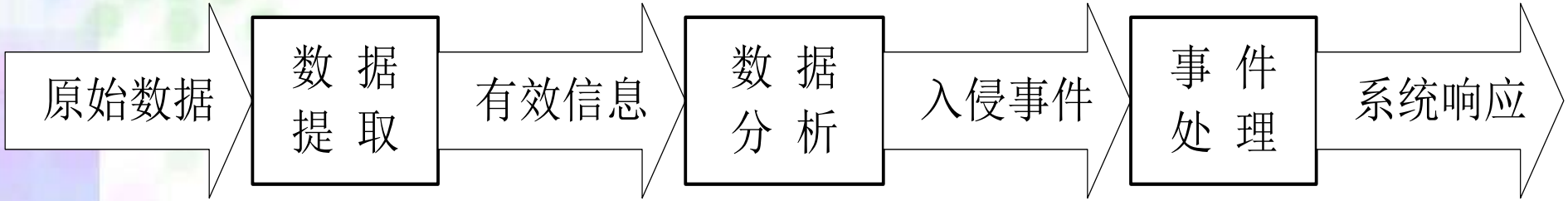
应用代理防火墙

- 应用代理防火墙也可以被称为代理服务器，它的安全性要高于包过滤型产品。
- 代理服务器位于客户机与服务器之间，客户首先将数据请求发给代理服务器，由代理服务器向服务器索取数据，然后再将数据传输给客户机。
- 特征：安全性高、速度较慢、配置复杂

西安交通大学 Xi'an Jiaotong University

网络入侵检测技术

- **入侵检测IDS的定义：**
  - ✓**对主机或网络系统的运行状态进行监视，发现各种攻击企图、攻击行为或者攻击结果，以保证系统资源的机密性、完整性和可用性的计算机安全技术。**
- **入侵检测框架**



西安交通大學
Xi'an Jiaotong University

入侵检测分类

- 根据采用的技术来分：
  - ✓异常检测（Anomaly detection）
  - ✓特征检测（Signature-based detection）
- 按检测的对象来分：
  - ✓基于主机的入侵检测系统
  - ✓基于网络的入侵检测系统
  - ✓基于网关的入侵检测系统

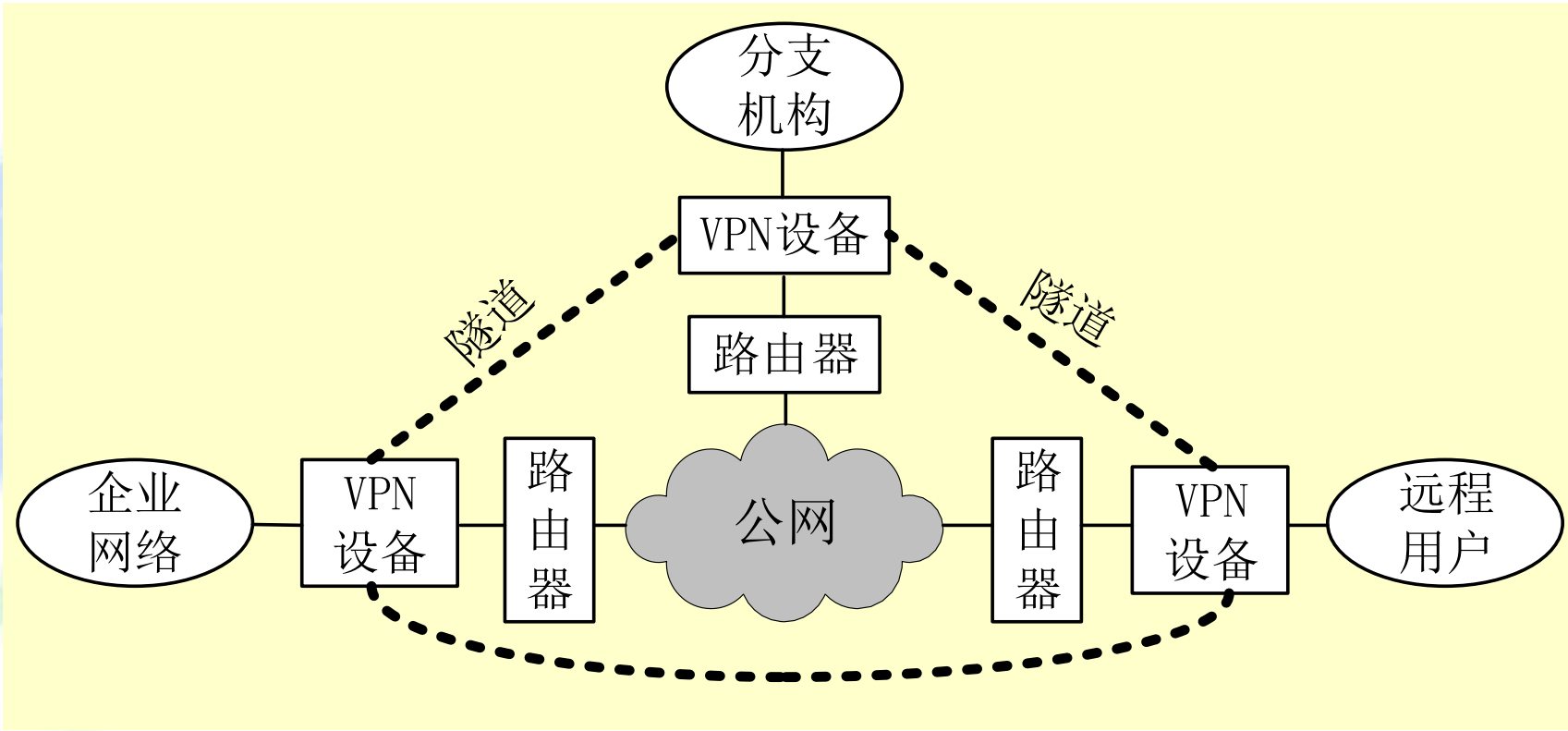
西安交通大學 Xi'an Jiaotong University

虚拟专用网VPN

- VPN网络的任意两个结点之间的连接并没有传统专网所需的端到端的物理链路。
- VPN是架构在公用网络服务商所提供的网络平台，如Internet、ATM或帧中继之上的**逻辑网络**。

西安交通大学 Xi'an Jiaotong University

VPN基本结构



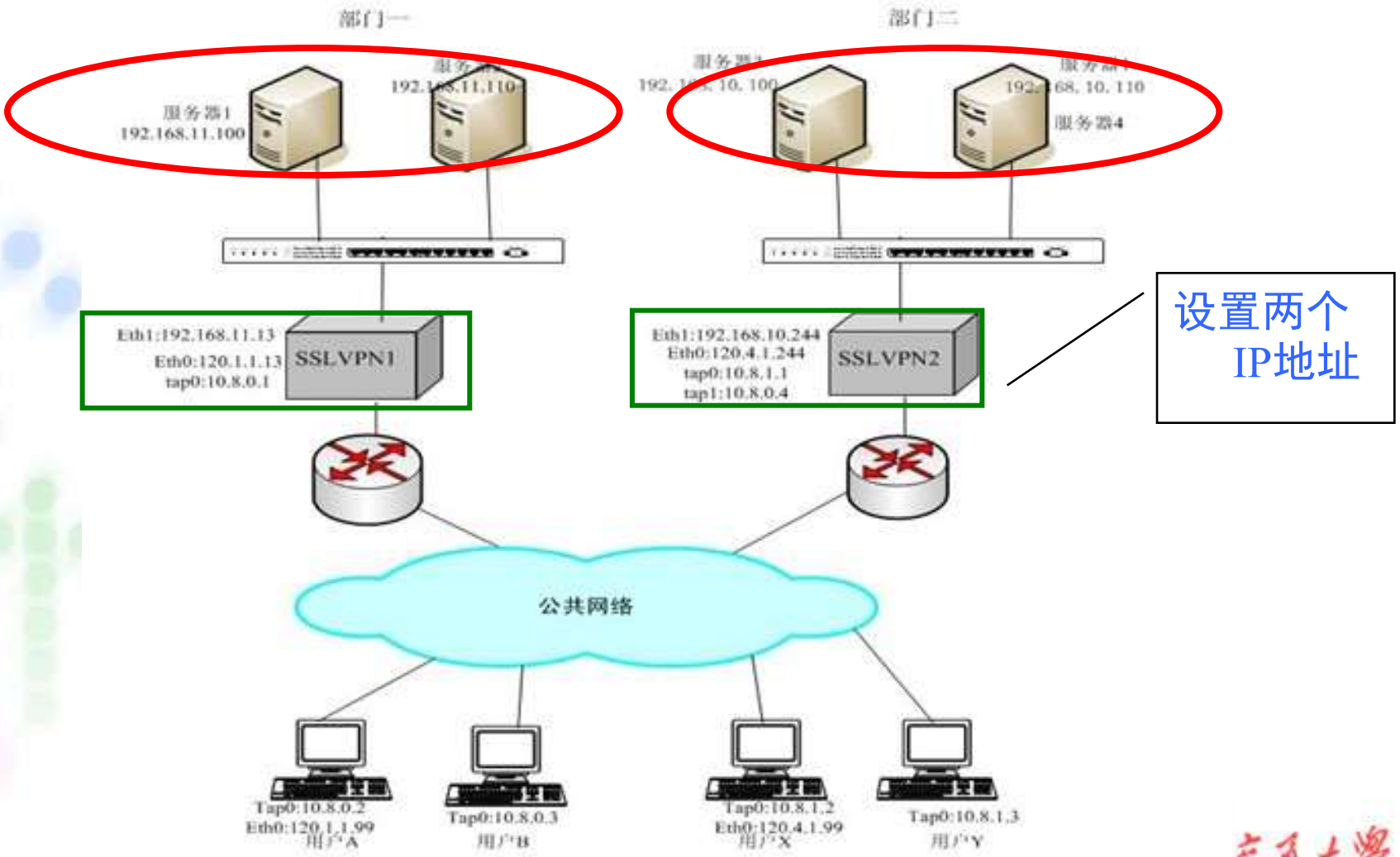
西安交通大学
Xi'an Jiaotong University

VPN的应用场景

- 例如：员工出差到外地，他想访问企业内网的服务器资源，怎么才能让外地员工访问到内网资源呢?
- 解决方法：在内网中架设一台VPN服务器，VPN服务器有两块网卡，一块连接内网，一块连接公网。

西安交通大学 Xi'an Jiaotong University

VPN应用场景



西安交通大学
Xi'an Jiaotong University

VPN使用的安全技术

- 隧道技术
- 加解密技术
- 设备身份认证技术
- 访问控制技术

西安交通大學
Xi'an Jiaotong University

VPN的特点

- 安全保障
- 成本较低
- 管理简单
- 扩展性强
- 服务质量保证

西安交通大學
Xi'an Jiaotong University

8.4 IPSec

- IPSec 即IP 安全(Security)协议
- 网络层保密是指所有在 IP 数据报中的数据都是加密的。
- 网络层还应提供源站鉴别，即目的站收到 IP 数据报时，能确信这是从该数据报的源 IP 地址的主机发来的。

西安交通大学 Xi'an Jiaotong University

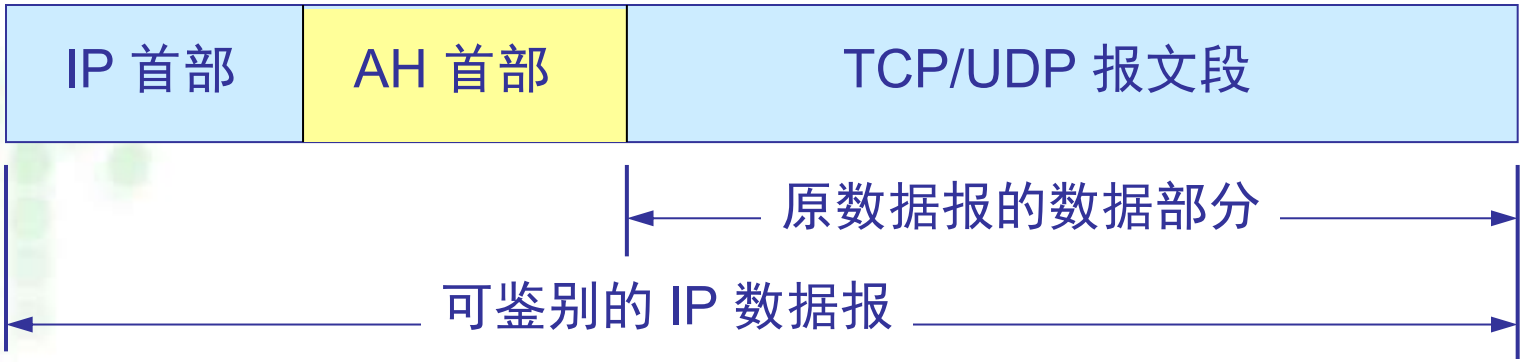
IPsec 构成

- 鉴别首部 AH (Authentication Header)：AH提供源站鉴别和数据完整性，但不能保密。
- 封装安全有效载荷 ESP (Encapsulation Security Payload)：ESP 提供源站鉴别、数据完整性和保密。

西安交通大学 Xi'an Jiaotong University

鉴别首部 AH

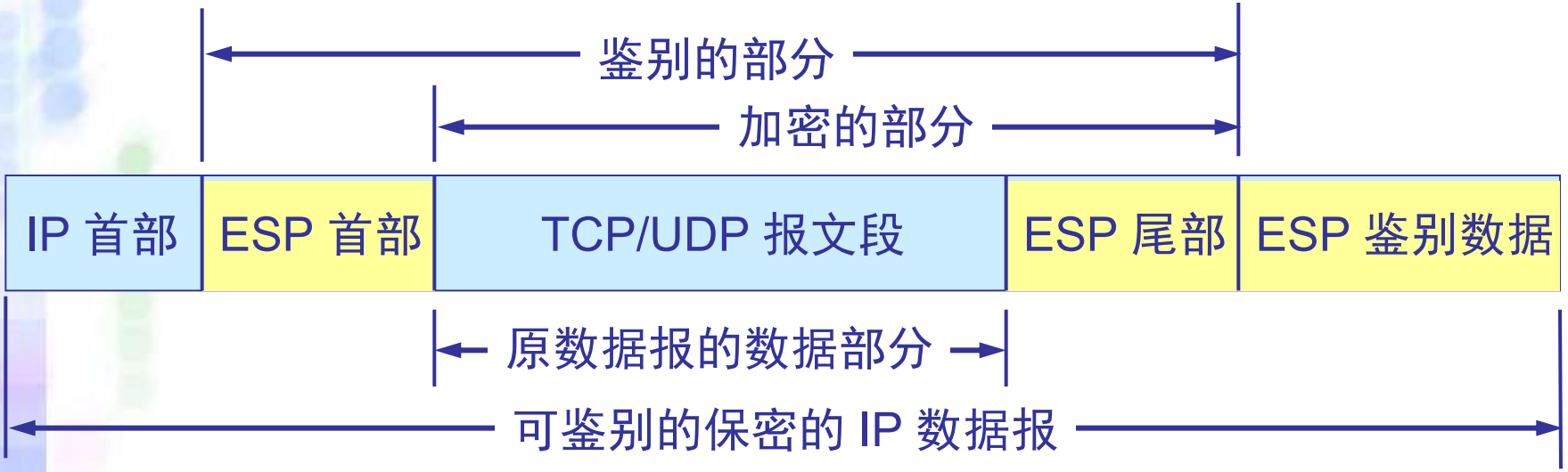
- 在使用鉴别首部 AH 时，将 AH 首部插在原数据报数据部分的前面。
- 当数据报到达目的站时，目的站主机处理 AH 字段，以鉴别源主机和检查数据报的完整性。



西安交通大學 Xi'an Jiaotong University

封装安全有效载荷 ESP

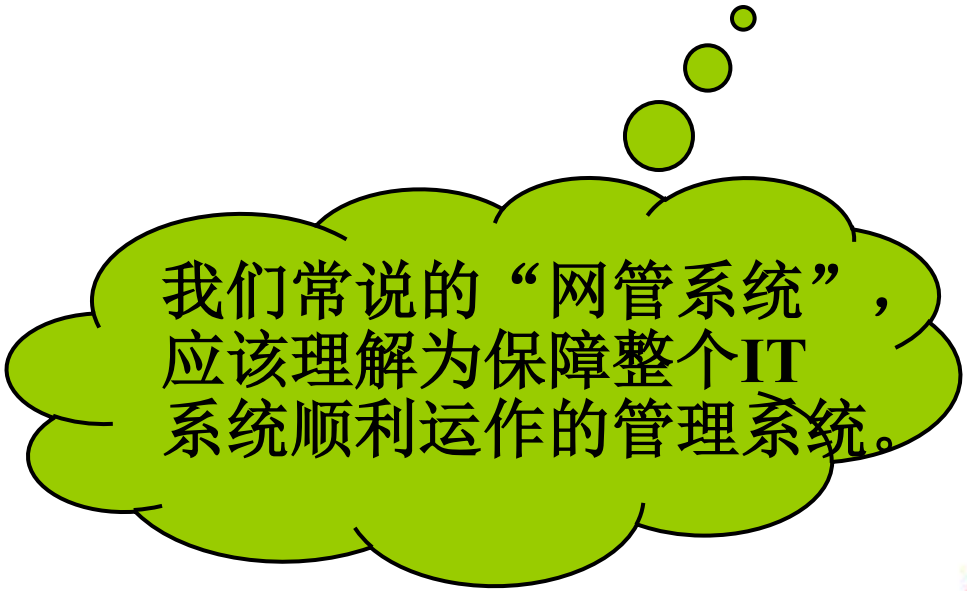
- 将 ESP 首部插在原数据报数据部分的前面。
- 用 ESP 封装的数据报既有鉴别源站和检查数据报完整性的功能，又能提供保密。



西安交通大學
Xi'an Jiaotong University

8.5 网络管理

- 网络管理是控制一个网络系统，使得它具有最高的效率和生产力的过程。
- 网络管理系统的本质是管理网络的软件系统。



西安交通大学
Xi'an Jiaotong University

网络管理的目标

- 解决异构设备的统一管理
- 提供高可靠的服务
- 提高网络的效率
- 提供公共的管理平台
- 提供友好的维护界面

西安交通大学 Xi'an Jiaotong University

网络管理的五大功能域

- 配置管理CM（Configuration Management）
- 故障管理FM（Fault Management）
- 性能管理PM（Performance Management）
- 计费管理AM（Accounting Management）
- 安全管理SM（Security Management）

西安交通大學 Xi'an Jiaotong University

网络运行周报2009.12.28-2010.01.04

2010-1-6 西安交通大学网络中心

发布日期：2010年01月06日

统计时间区间:2009-12-28 至 2010-01-04

一、本周用户服务数据

项目	数据
IP入网新用户	38 户
开通电子邮件	0 户
开通代理用户	0 户
家属区新开通用户	6 户
新开通XJTU子域名	7 个
上门处理用户网络故障	17 次
设备安装及网络工程	0 次
查处中病毒端口	36 个
查处地址盗用	9 起

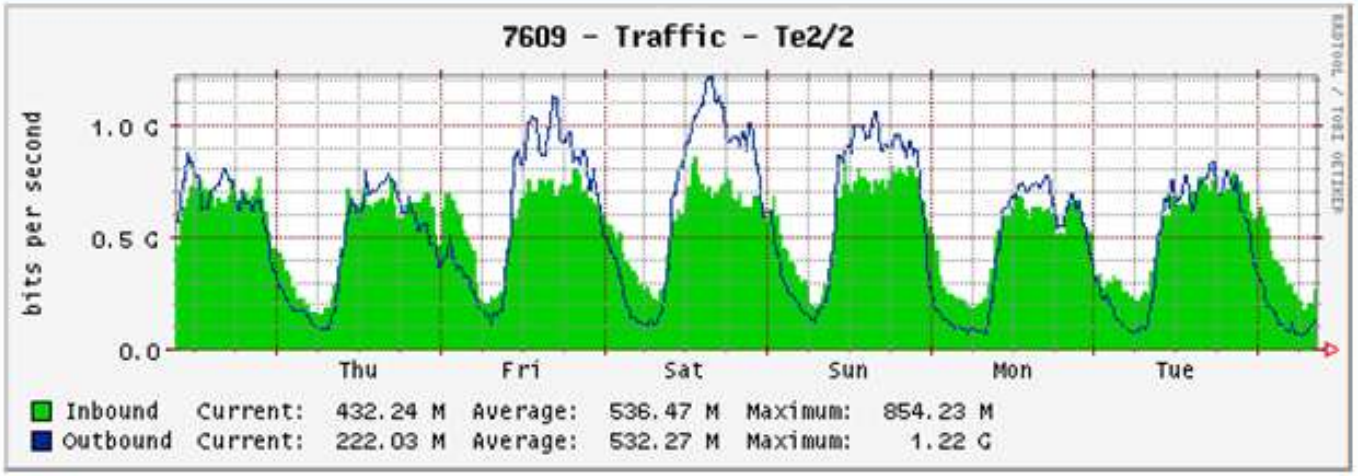
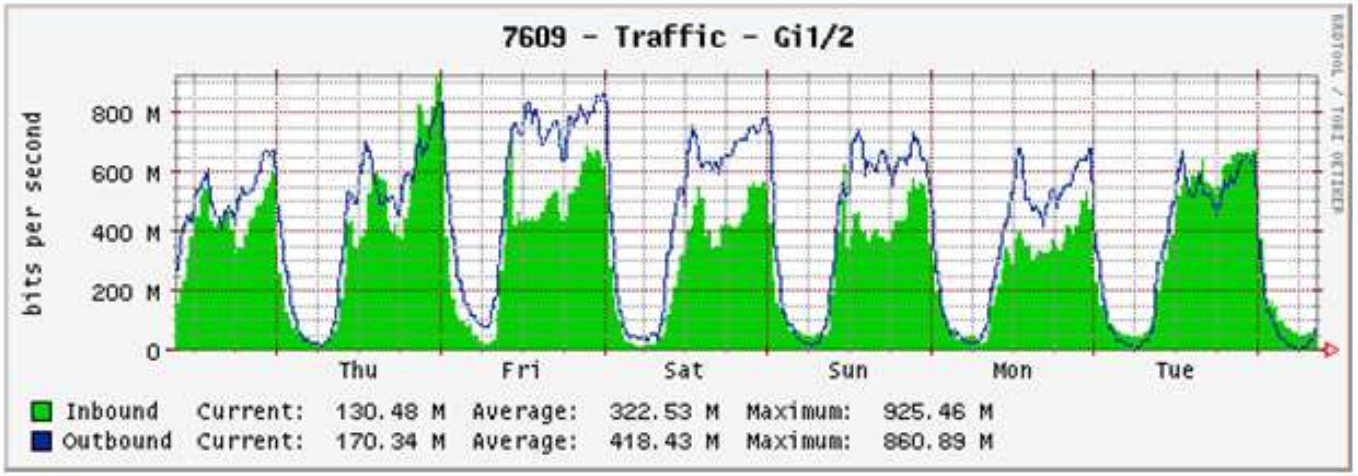
西安交通大学 Xi'an Jiaotong University

二、网络运行情况

项目	数据
主干设备正常可靠运行率	100%
主干设备故障次数	0 次
主干设备累计故障时间	0 小时
楼层交换机正常可靠运行率	99.96%
主机房空调电源可靠运行率	100%
主机房空调电源故障次数	0 次
本周网络安全情况通报	本周多次中毒的IP地址:
本周重要网络运行事件	无
网络工程进展情况通报	无
垃圾邮件拦截比率	86.27%
病毒邮件比例	0.01%
邮件网关流量	入流量:146.4 GB ; 出流量:133.2 GB ;

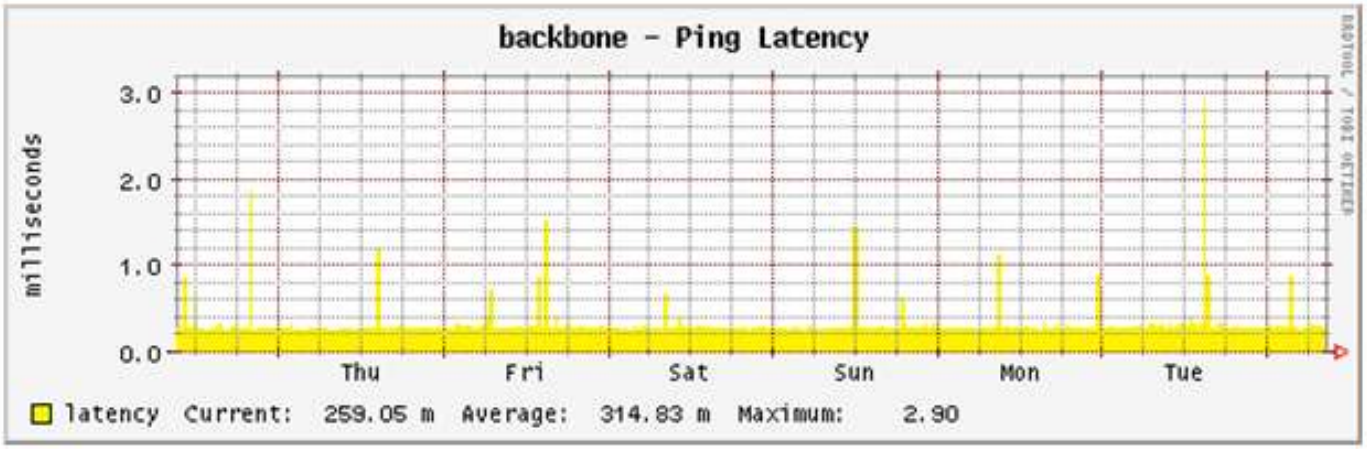
西安交通大学 Xi'an Jiaotong University

三、网络主干流量图

项目	数据
教学区国内出口流量	
学生区出口流量	

西安交通大學 Xi'an Jiaotong University

四、网络延迟情况测试

项目	数据
到主干（6513－1)延迟周测试图表	

五、服务器运行情况

项目	数据				
主要公共信息服务器服务可用率	www主页服务器	域名服务器	邮件网关	WEBMAIL	学生邮件服务器
	100%	100%	99.68%	100%	100%
	单位主页服务器	FTP服务器	BBS服务器	VOD服务器	MUSIC服务器
	100%	100%	100%	100%	99.78%

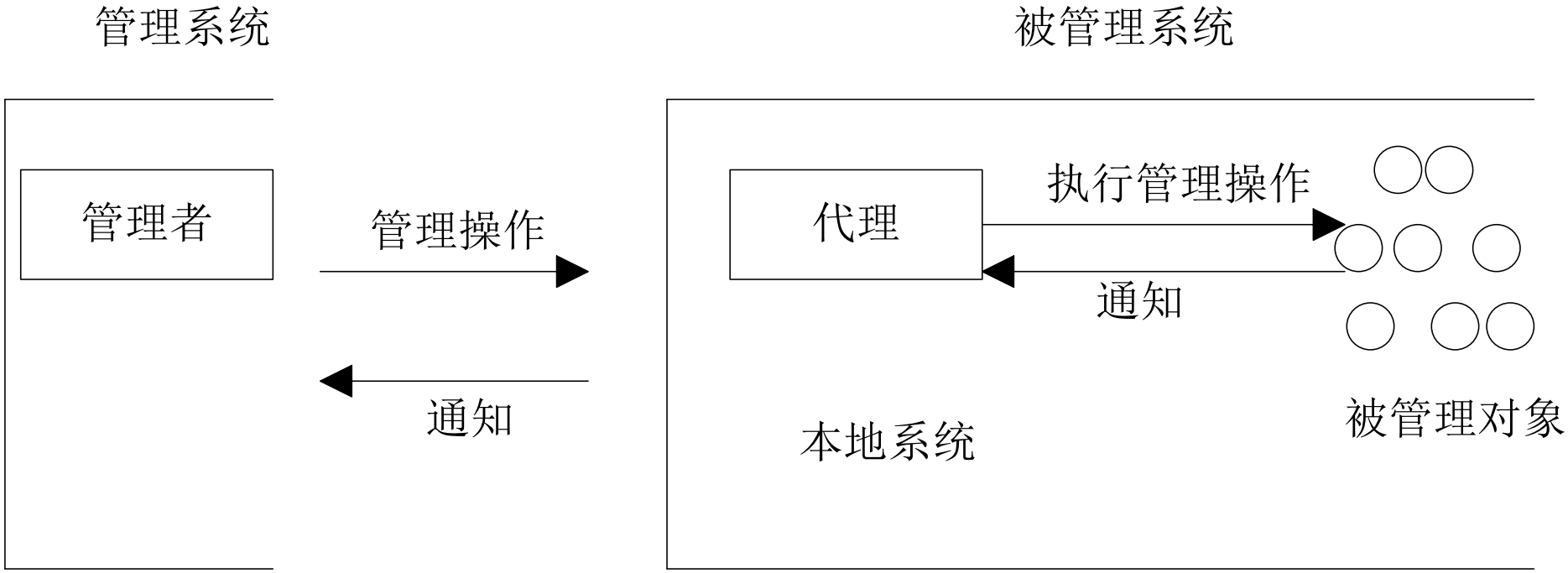
西安交通大学 Xi'an Jiaotong University

网络管理模型

- 在网络管理中，一般采用管理者-代理的管理模型。
- 管理者负责发出管理操作的指令，并接收来自代理的信息。
- 代理则位于被管理的设备内部，把来自管理者的命令或信息请求转换为本设备特有的指令。

西安交通大学 Xi'an Jiaotong University

管理者/代理之间的通信



西安交通大学
Xi'an Jiaotong University

SNMP协议

- 常用的网络管理协议包括：
  - ✓简单网络管理协议（Simple Network Management Protocol，SNMP），SNMP目前被广泛地实现在各种网络设备中，并在Internet中普遍使用。
  - ✓公共管理信息协议（Common management information protocol，CMIP）

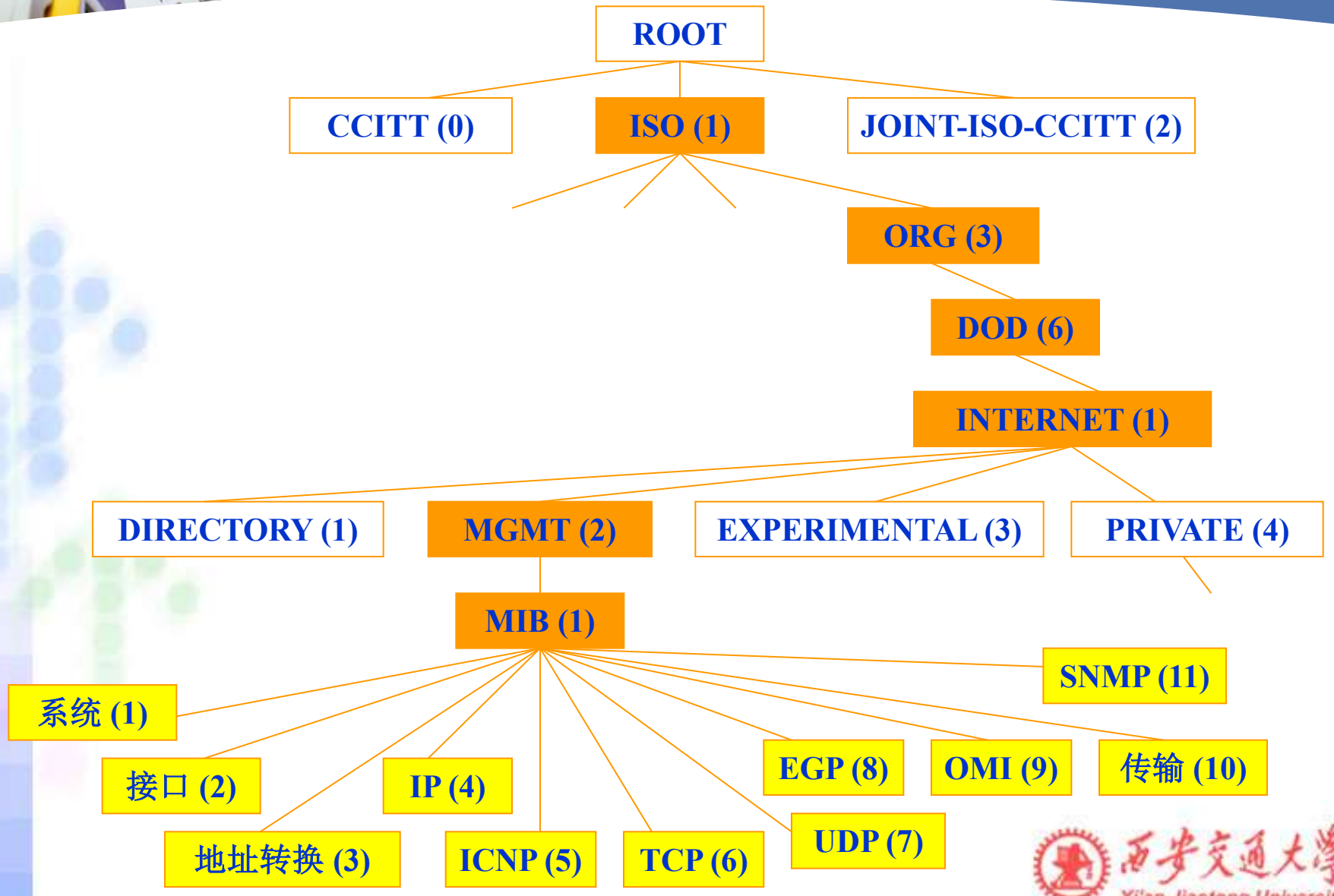
西安交通大学 Xi'an Jiaotong University

管理信息库（MIB）

- 所有的被管对象都包含在MIB中（Management Information Base ）
- 一个MIB可以描述为一棵抽象树，树的根没有名字，各个数据项组成了树的叶节点。

西安交通大学 Xi'an Jiaotong University

MIB树



西安交通大學 Xi'an Jiaotong University

对象标识符（OID）

- 对象标识符（OID）唯一地标识或命名了树中的各种MIB对象。
- 例如：对于变量sysDescr，其名字为：

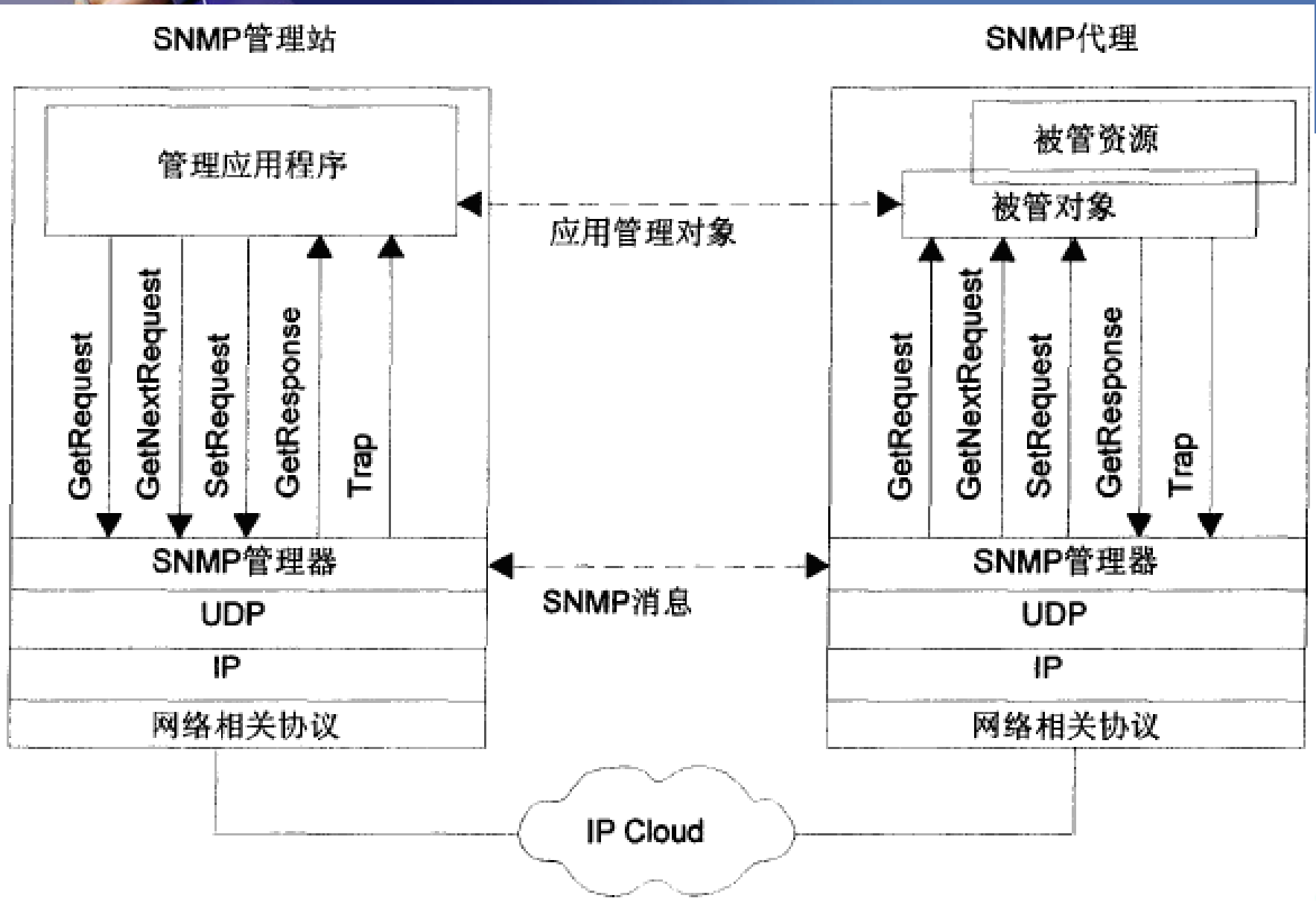
  .iso.org.dod.internet.mgmt.mib.system.sysDesc，其相应的数字表示为：.1.3.6.1.2.1.1.1

西安交通大学 Xi'an Jiaotong University

SNMP通信协议与报文格式

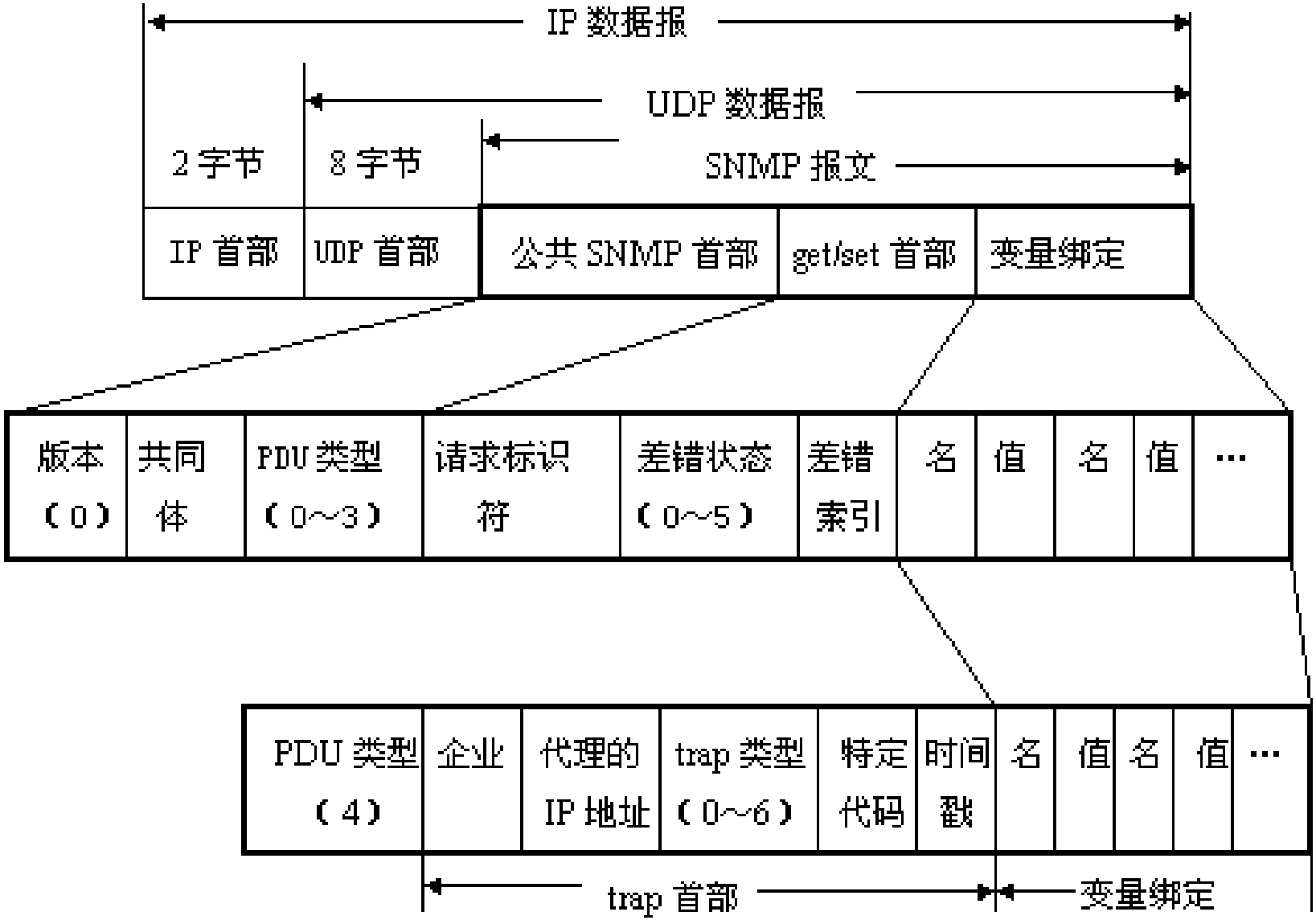
- **GetRequest**：从代理进程处提取一个或多个参数值；
- **GetNextRequest**：从代理进程处提取紧跟当前参数值的下一个参数值；
- **SetRequest**：设置代理进程的一个或多个参数值；
- **GetResponse**：返回的一个或多个参数值。这个操作是由代理进程发出的，它是前面三种操作的响应操作;
- **Trap**：代理进程主动发出的报文，通知管理进程有某些事情发生。

西安交通大学 Xi'an Jiaotong University



SNMP原语

西安交通大學 Xi'an Jiaotong University



SNMP报文格式

西安交通大學 Xi'an Jiaotong University

- **中心化系统不足**
  - ✓信息分散在各中心手中，打通成本非常大
  - ✓信息要按照中心化机构的体系要求进行运
  - ✓作
  - ✓中心化系统安全性保障难度大（黑客攻击，自然灾害等）
  - ✓内部人员的篡改，信用缺乏保障

区块链概念

区块链（BlockChain）定义

- ✓ 区块链是一种使用去中心化共识机制去维护一个完整的、分布式的、不可篡改的账本数据库的技术，它能够让区块链中的参与者在无需建立信任关系的前提下实现一个统一的账本系统。

西安交通大学 Xi'an Jiaotong University

区块链特征

- **不同视角下的区块链**
  - ✓从数据的角度来看：分布式数据库（存储与记录），P2P的自组织网络
  - ✓从效果的角度来看：时间顺序、不可篡改的、可信任的数据库
  - ✓多种现有技术的整合：加密算法，P2P文件传输，时间戳，数据库等
- **区块链关键点**
  - ✓去中心化、去信任、集体维护、可靠数据库、时间戳、非对称加密

西安交通大學 Xi'an Jiaotong University

区块链工作流程

- **三个环节**
  - ✓生成区块。区块链节点收集通过广播在网络中的交易，然后将这些交易打包成区块。
  - ✓共识验证。节点将区块广播至网络中，全网节点接收大量区块后进行顺序的共识和内容的验证，形成账本。
  - ✓账本维护。节点长期存储验证通过的账本数据并提供回溯检验等功能，为上层应用提供账本访问接口。

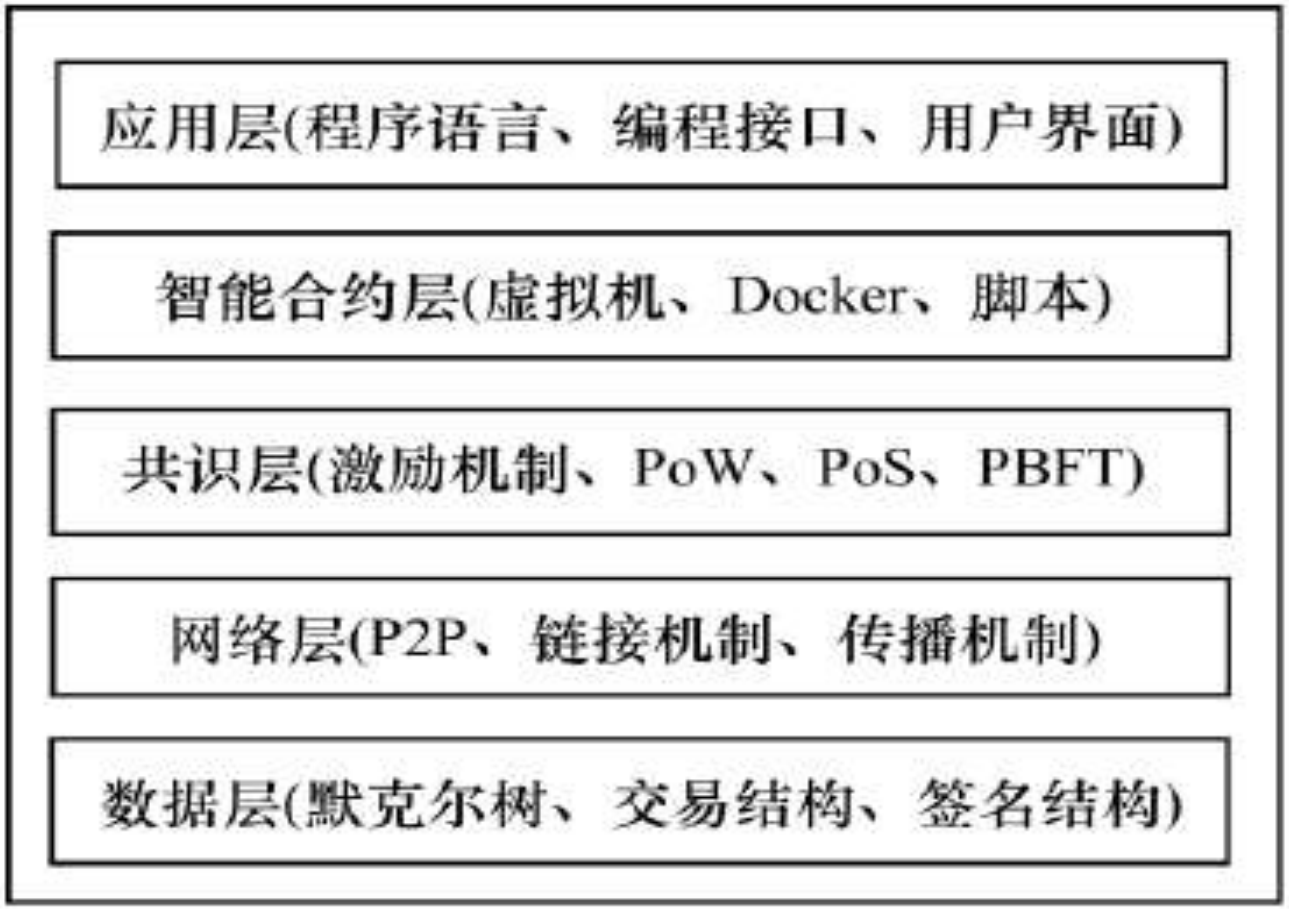
西安交通大学 Xi'an Jiaotong University

区块链类型

- 按发展阶段划分
  - ✓区块链1.0：称为可编程货币阶段
  - ✓区块链2.0：称为可编程金融阶段
  - ✓区块链3.0：称为可编程社会阶段
- 按应用场景划分
  - ✓非许可链：也称为公链/公有链，是一种完全开放的区块链，即任何人都可以加入网络并参与完整的共识记账过程。
  - ✓许可链：细分为联盟链和私链/私有链，半开放式的区块链，只有指定的成员可以加入网络，且每个成员的参与权各有不同。

西安交通大学 Xi'an Jiaotong University

区块链平台架构



西安交通大學 Xi'an Jiaotong University

区块链共识算法

- **什么是共识算法**
  - ✓共识算法实质上就是一个规则，每个区块链节点都按照这个规则去确认各自的数据，进而实现不同账本节点上的账本数据的一致性和正确性。
- **常用共识算法**
  - ✓PoW、PoS、DPOS、PBFT
  - ✓评价标准：执行代价、去中心化程度、容错能力、吞吐量、时延

西安交通大学 Xi'an Jiaotong University

主流区块链平台

对比内容	比特币	以太坊	超级账本
技术成熟度	成熟	成熟	成熟
开源情况	开源	开源	开源
共识算法	PoW	PoW/PoS	Kafka/Solo/PBFT
智能合约	不支持	支持	支持
发放代币	比特币	以太币	-
区块链形态	公有链	公有链为主，支持联盟链/私有链	联盟链为主，支持私有链

西安交通大学 Xi'an Jiaotong University